MÒDUL 06 · SEGURETAT INFORMÀTICA — RA4 · NF5-AA4

Tallafocs (Firewall)

El porter digital que decideix qui entra i qui surt

CFGM Sistemes Microinformàtics i Xarxes · 2n curs

Institut Puig Castellar
Joan Sánchez

EN AQUESTA SESSIÓ

Què aprendrem avui?



Tipus de tallafocs

Per maquinari, per programari, de xarxa i personal: on se situa cadascun i què protegeix.



Polítiques de filtratge

Denegació per defecte vs. permissió per defecte: dues filosofies oposades de seguretat.



UFW en pràctica

Configuració real de regles de tallafocs a Linux amb Uncomplicated Firewall.

HO SABIES?

El primer tallafocs: un concepte del món físic

D'on ve el nom

El terme "firewall" prové de la construcció: una paret tallafocs és una paret dissenyada per aturar la propagació d'un incendi entre dues zones d'un edifici. Un tallafocs informàtic fa exactament el mateix amb el trànsit de xarxa: n'atura la propagació no autoritzada.

No és una solució màgica

Un tallafocs NOMÉS filtra trànsit segons regles: no detecta malware dins d'un fitxer permès, ni protegeix d'un atac d'enginyeria social. Cal combinar-lo sempre amb altres mesures (antivirus, IDS/IPS, formació).

DEFINICIÓ

Què és un tallafocs

Sistema (maquinari, programari o ambdós) que controla el trànsit de xarxa entrant i sortint, permetent o bloquejant-lo segons un conjunt de regles de seguretat predefinides.

- Actua com a barrera entre una xarxa de confiança (interna) i una de no confiança (Internet, o una altra subxarxa).
- Filtra pel que fa a adreces IP, ports, protocols, i en els tallafocs més avançats, també pel contingut o l'estat de la connexió.

ON SE SITUA

Tipus de tallafocs segons la ubicació

Tipus	Ubicació i funció
De maquinari / perimetral	Dispositiu dedicat entre la xarxa interna i Internet; protegeix tota una organització (pfSense, Fortinet, Cisco ASA).
De programari / d'equip	Instal·lat al propi sistema operatiu; protegeix un únic equip (UFW/iptables a Linux, Windows Defender Firewall).
Personal	Similar al de programari, orientat a usuaris domèstics, sovint integrat en suites de seguretat.

SEGONS LA TECNOLOGIA

Filtratge de paquets vs. inspecció d'estat



Filtratge de paquets (stateless)

Analitza cada paquet de manera independent (IP origen/destí, port, protocol), sense recordar el context de la connexió. Ràpid, però menys segur.



Inspecció d'estat (stateful)

Manté una taula amb l'estat de cada connexió activa, i només permet trànsit de resposta a connexions ja establertes des de dins. Estàndard actual.



Els tallafocs de nova generació (NGFW) hi afegeixen inspecció profunda de paquets (DPI), IDS/IPS integrat i filtratge per aplicació.

DUES FILOSOFIES OPOSADES

Polítiques de filtratge



Denegació per defecte (whitelist)

Es bloqueja TOT per defecte, i només es permet explícitament allò necessari. Més segura, però requereix més manteniment inicial.



Permissió per defecte (blacklist)

Es permet TOT per defecte, i només es bloqueja explícitament allò conegut com a perillós. Més còmoda, però insegura davant amenaces desconegudes.



Bona pràctica recomanada: denegació per defecte en trànsit ENTRANT, permissió per defecte en trànsit SORTINT (mentre no hi hagi motiu per restringir-lo).

DMZ: la zona desmilitaritzada

- Una DMZ és una subxarxa intermèdia entre la xarxa interna (protegida) i Internet, on se situen els serveis que han de ser accessibles des de l'exterior (servidor web, correu, DNS públic).
- Si un atacant compromet un servidor de la DMZ, el tallafocs impedeix que pugui saltar directament a la xarxa interna, limitant l'abast del dany.

PRÀCTICA REAL

Configurant un tallafocs amb UFW (Linux)

- UFW (Uncomplicated Firewall) simplifica la gestió d'iptables/nftables amb una sintaxi molt més llegible.



"ufw default deny incoming" aplica denegació per defecte; "ufw allow 22/tcp comment '...'" obre un port concret amb una nota explicativa; "ufw deny from <IP>" bloqueja una IP concreta; "ufw enable" activa el tallafocs; "ufw status verbose" mostra totes les regles actives. Ho practicareu amb captures reals a l'exercici guiat.

MANTENIMENT

Gestionar regles al llarg del temps

- Amb "ufw status numbered" cada regla apareix amb un número, que permet eliminar-la fàcilment amb "ufw delete <número>".
- Un tallafocs mal mantingut, amb regles obsoletes acumulades amb els anys, és un risc de seguretat tan gran com no tenir-ne: cal revisar-lo periòdicament.



Precaució pràctica: en configurar un tallafocs remot (per exemple, via SSH), assegura't SEMPRE de permetre el port d'administració (22/tcp) ABANS d'activar la denegació per defecte, o et quedaràs fora del sistema.

PER ACABAR

Idees clau d'avui



Barrera controlada

Un tallafocs filtra el trànsit segons regles, però NO és una solució completa: cal combinar-lo amb antivirus, IDS/IPS i formació.



Denegació per defecte

La política més segura: bloquejar tot i permetre només el necessari, especialment en trànsit entrant.



UFW: simplicitat pràctica

Una eina accessible per gestionar un tallafocs real a Linux amb una sintaxi clara i llegible.

ARA ÉS EL TORN VOSTRE



Una petita empresa vol exposar el seu servidor web (port 80/443) a Internet, mantenint alhora protegit el servidor de fitxers intern.

En parelles: dissenyeu, amb un esquema senzill, com organitzaríeu la xarxa (relacioneu-ho amb el concepte de DMZ) i quines regles bàsiques de tallafocs (UFW) aplicaríeu a cada zona.

10 minuts en parelles + posada en comú

FONTS DEL MATERIAL

Webgrafia

NF5-AA4: Tallafocs

Repositori "Materials" (GitHub, SMX-0226SI) · Carlos Alonso Martínez, Escola Pia de Mataró · Llicència CC-BY-SA-4.0

UFW — documentació oficial (Ubuntu)

help.ubuntu.com/community/UFW

Cloudflare — What is a firewall?

cloudflare.com/learning/security/what-is-a-firewall

pfSense (tallafocs perimetral de codi obert)

pfsense.org

Llicència CC BY-SA 4.0 · Adaptat de "Materials" (SMX-0226SI), Carlos Alonso Martínez, Escola Pia de Mataró